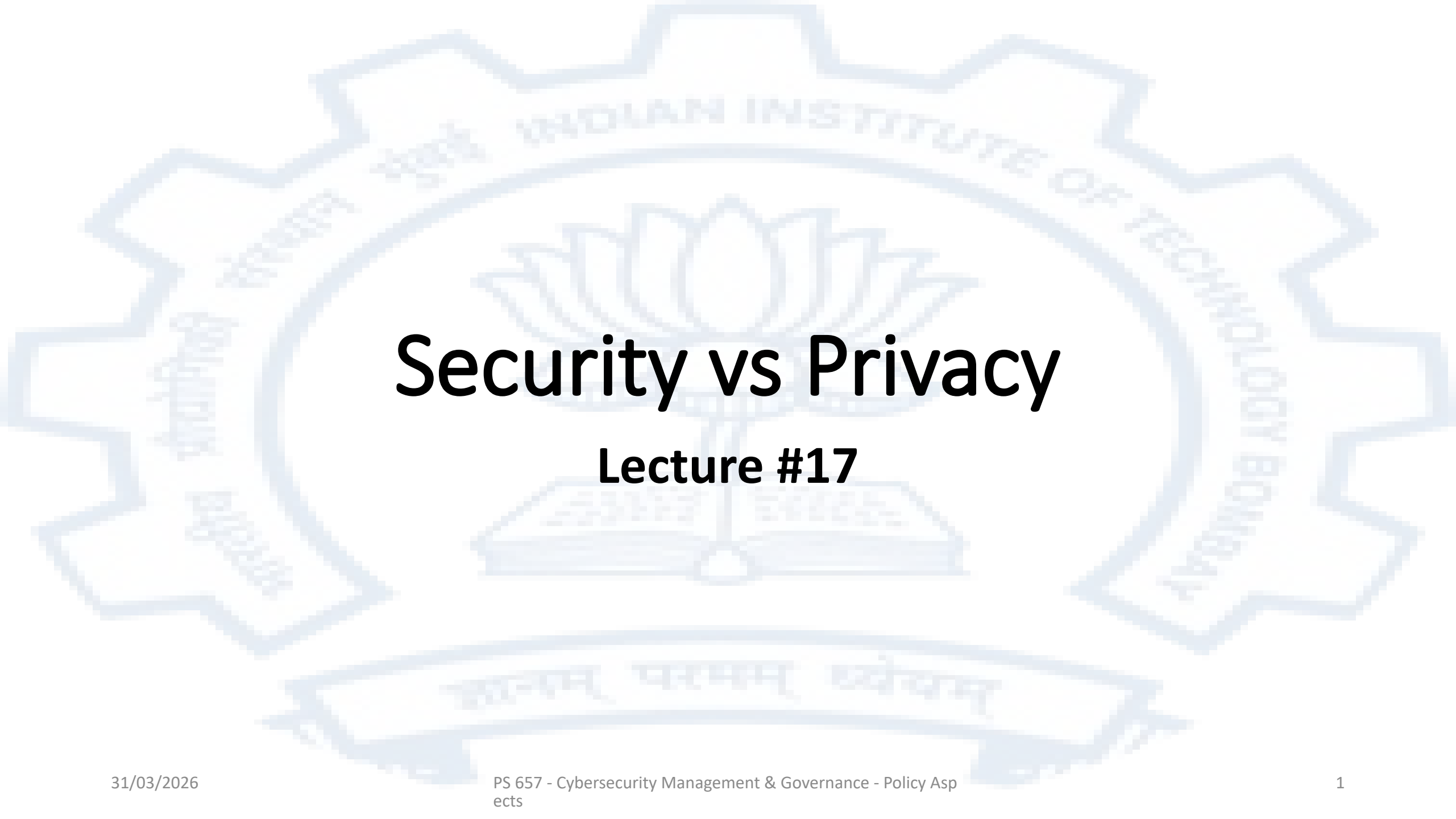




Security vs Privacy

Lecture #17

The basic dilemma

- On one hand the nature of modern online systems is such that strong security is required to instill confidence in the usage of such systems. The security concerns are typically
 - Privacy – revealing sensitive data gives an adversary significant undesirable leverage, and cause damage to reputation and even pose a physical risk
 - Financial Loss – poor security allows fraudulent transactions to be carried out
 - Data destruction – irreparable loss of data
- The underlying technology to enable security is strong encryption
- On the other hand, a Government may sometimes need to monitor or intercept data or communications or monitor them for certain legitimate purposes. The use of strong encryption may significantly hamper this objective

Reasons for a Government to intercept communications

The two major reasons are

1. Intelligence gathering, either aimed at protecting the security of the state (terrorists, separatists, agents of another state) or the safety of the public (organized crime)
2. Investigation of a crime

Strategic Threats

- Threats from Nation States
 - Mitigation strategies
 - Military superiority
 - Action via UN
 - Military
 - Economic sanctions
- Threats from non-Nation State Actors
 - Mitigation strategies
 - Intelligence gathering
 - Preemptive law enforcement action

The “Clipper Chip”

- On April 16, 1993, the White House announced the so-called “Clipper chip.” Officially known as the MYK-78, it was intended for use in secure communication devices like crypto phones. The chip’s cryptographic algorithm, known as Skipjack, was developed by the (NSA)
- In 1993, AT&T Bell produced the first and only telephone device based on the Clipper chip.
- At the heart of the concept was key escrow. In the factory, any new telephone or other device with a Clipper chip would be given a cryptographic key, that would then be provided to the government in escrow. If government agencies "established their authority" to listen to a communication, then the key would be given to those government agencies, who could then decrypt all data transmitted by that particular telephone.

The fallout

- Various organizations challenged the Clipper chip proposal, saying that it would have the effect not only of subjecting (US) citizens to increased and possibly illegal government surveillance, but that the strength of the Clipper chip's encryption could not be evaluated by the public as its design was classified secret, and that therefore individuals and businesses might be hobbled with an insecure communications system
- In 1994, Matt Blaze published the paper *Protocol Failure in the Escrowed Encryption Standard*. It pointed out that the Clipper's escrow system has a serious vulnerability: the chip transmitted a 128-bit "Law Enforcement Access Field" (LEAF) that contained the information necessary to recover the encryption key.
- The release and development of several strong cryptographic software packages such as Nautilus, PGP and PGPfone was in response to the government push for the Clipper chip. The thinking was that if strong cryptography was freely available on the internet as an alternative, the government would be unable to stop its use.
- The system was never really adopted and by 1996 interest in it had almost ceased

Breaking Encryption

- Modern ciphers are designed to ensure that knowledge of the algorithm will not provide any advantage if the keys are kept secret.
- This means the key lengths have to be chosen so that brute force attacks (trying all possible keys) are not computationally practical
- The standard encryption algorithm in use today is AES-256. Each key is 256 bits. The number of possible keys is therefore 2^{256} . If you were able to try a billion (10^9) keys a second it would still take of the order of 10^{58} billion years to try all keys.

Operation Aurora

- On January 12, 2010, Google revealed on its blog that it had been the victim of a cyber attack. The company said the attack occurred in mid-December and originated from China. Google stated that over 20 other companies had been attacked; other sources have since cited that more than 34 organizations were targeted. As a result of the attack, Google said it was reviewing its business in China. On the same day, United States Secretary of State Hillary Clinton issued a brief statement condemning the attacks and requesting a response from China.
- On January 13, 2010, the news agency All Headline News reported that the United States Congress plans to investigate Google's allegations that the Chinese government used the company's service to spy on human rights activists.

Operation Shady RAT

An investigation of targeted intrusions into more than 70 global companies, governments, and non-profit organizations during the last five years

Lately, with the rash of revelations about attacks on organizations such as RSA, Lockheed Martin, Sony, PBS, and others, I have been asked by surprised reporters and customers whether the rate of intrusions is increasing and if it is a new phenomenon. I find the question ironic because these types of exploitations have occurred relentlessly for at least a half decade, and the majority of the recent disclosures in the last six months have, in fact, been a result of relatively unsophisticated and opportunistic exploitations for the sake of notoriety by loosely organized political hacktivist groups such as Anonymous and Lulzsec.

On the other hand, the targeted compromises we are focused on—known as advanced persistent threats (APTs)—are much more insidious and occur largely without public disclosures. They present a far greater threat to companies and governments, as the adversary is tenaciously persistent in achieving their objectives. The key to these intrusions is that the adversary is motivated by a massive hunger for secrets and intellectual property; this is different from the immediate financial gratification that drives much of cybercrime, another serious but more manageable threat.

Revealed: Operation Shady RAT By Dmitri Alperovitch, Vice President, Threat Research, McAfee - 2011

Operation Shady RAT

An investigation of targeted intrusions into more than 70 global companies, governments, and non-profit organizations during the last five years

- *Having investigated intrusions such as Operation Aurora and NightDragon (the systemic long-term compromise of Western oil and gas industry), as well as numerous others that have not been disclosed publicly, I am convinced that every company in every conceivable industry with significant size and valuable intellectual property and trade secrets has been compromised (or will be shortly), with the great majority of the victims rarely discovering the intrusion or its impact. In fact, I divide the entire set of Fortune Global 2,000 firms into two categories: those that know they've been compromised and those that don't yet know*
- *What we have witnessed over the past five to six years has been nothing short of a historically unprecedented transfer of wealth—closely guarded national secrets (including those from classified government networks), source code, bug databases, email archives, negotiation plans and exploration details for new oil and gas field auctions, document stores, legal contracts, supervisory control and data acquisition (SCADA) configurations, design schematics, and much more has “fallen off the truck” of numerous, mostly Western companies and disappeared in the ever-growing electronic archives of dogged adversaries.*

Revealed: Operation Shady RAT By Dmitri Alperovitch, Vice President, Threat Research, McAfee - 2011

Advanced Persistent Threats- APTs

- Nomenclature was coined by the US Air Force in 2006 with Colonel Greg Rattray being generally believed to have coined the term
- Refers to an entity (threat actor) with considerable skill that manages to infiltrate computer networks and systems and remain undetected for long periods of time
- This signaled a change in the nature of hacker from the early hackers that wanted to create visible damage to draw attention to themselves or a cause to those that were intent on industrial and state targeted espionage

Global Terrorist Groups – Some examples

- Al-Qaeda is a Sunni pan-Islamist militant organization led by Salafi jihadists who self-identify as a vanguard spearheading a global Islamist revolution to unite the Muslim world under a supra-national Islamic state known as the Caliphate. Its members are mostly composed of Arabs, but also include other peoples. Al-Qaeda has mounted attacks on civilian and military targets in various countries, including the 1998 United States embassy bombings and the September 11 attacks; it has been designated as a terrorist group by the United Nations Security Council, the North Atlantic Treaty Organization (NATO), the European Union, and various countries around the world.
- The Islamic State (IS) - also known as the Islamic State of Iraq and the Levant (ISIL; [/ˈaɪsɪl/](#)), Islamic State of Iraq and Syria (ISIS), and by its Arabic acronym Da'ish — is a Salafi jihadist transnational Islamist terror group and former unrecognised quasi-state. It was founded by Abu Musab al-Zarqawi in 1999 and gained global prominence in 2014, when its militants conquered large territories in northwestern Iraq and eastern Syria, aided by the Syrian civil war. By the end of 2015, it ruled an area with an estimated population of twelve million people, where it enforced its interpretation of Islamic law, administered an annual budget of more than US\$1 billion, and had more than 30,000 fighters under its command. After years of intense and grinding combat with American, Iraqi, and Kurdish forces, by 2019 it had lost all its Middle Eastern territories and returned to insurgency tactics in the regions it once controlled, operating from remote hideouts and continuing its propaganda efforts, which have gained it a strong following in northern and Sahelian Africa.
- The UN Security Council has designated more than 50 entities as terrorist groups

There are thousands of smaller entities that threaten specific countries or small geographic regions

Source: Wikipedia

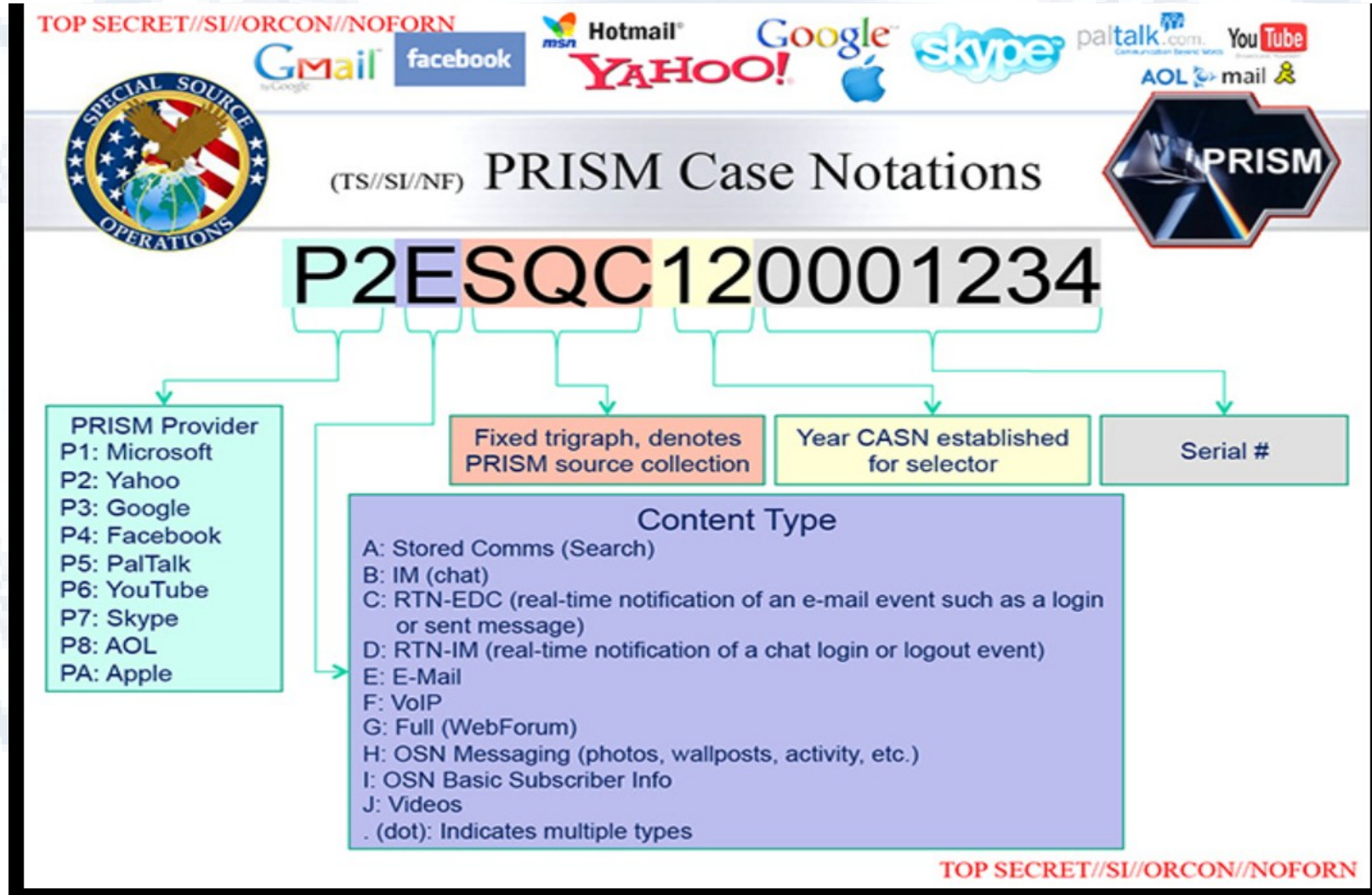
Funding of Terrorism

- Terrorism activities take place in many different forms ranging from isolated acts to planned activities of organised groups. The forms of financing of terrorism therefore vary accordingly. It comprises not only the financing of the terrorist acts as such, but also any support to the criminal network. Terrorist organisations require significant funding, both for the actual undertaking of terrorist acts, but also to other issues : to maintain the functioning of the organisation, to provide for its basic technical necessities, as well as to cover costs related to spreading related ideologies.
 - The sources of terrorist funding vary. Firstly, they may originate from illegal activities, ranging from low-scale criminality to organised crime (e.g. trafficking in drugs, weapons or human beings.) The origin of the funds might, however, also be legitimate, being provided for example by the members of the organisation (usually the newcomers) or obtained through the abuse of non-profit organisations. New funding techniques of terrorist organisations were recently identified by the FATF in respect of Da'esh (also known as the “Islamic State”). Given the way of its functioning, Da'esh resorted to new methods of funding which could be considered more inherent for a state, such as leveraging taxes or exploiting natural resources (such as in this case natural gas and oil)
- <https://www.eoe.int/en/web/moneyval/implementation/financing-terrorism>

The Snowden Revelations

- **Edward Joseph Snowden** (born June 21, 1983) is a United States and naturalized Russian citizen who was a computer intelligence consultant and whistleblower who leaked highly classified information from the National Security Agency (NSA) in 2013 when he was an employee and subcontractor. His disclosures revealed numerous global surveillance programs, many run by the NSA and the Five Eyes intelligence alliance with the cooperation of telecommunication companies and European governments and prompted a cultural discussion about national security and individual privacy.
- *"I, sitting at my desk [could] wiretap anyone, from you or your accountant, to a federal judge or even the president, if I had a personal email."*
- It was revealed that the NSA was harvesting millions of email and instant messaging contact lists, searching email content, tracking and mapping the location of cell phones, undermining attempts at encryption via Bullrun and that the agency was using cookies to piggyback on the same tools used by Internet advertisers "to pinpoint targets for government hacking and to bolster surveillance." The NSA was shown to be secretly accessing Yahoo and Google data centers to collect information from hundreds of millions of account holders worldwide by tapping undersea cables using the MUSCULAR surveillance program.

PRISM



FBI v/s Apple

- 9th Feb 2016 - FBI announces that it is unable to gain access to the data in a locked i-Phone that was recovered from the person of one of the two attackers responsible for a mass shooting in San Bernadino – California.
- FBI asks Apple to create a new version of their operating system that will bypass the security checks including the erasure feature and will run in the RAM of the phone.
- Apple declines to comply with the FBI request
- FBI approaches the court applying to have an order issued that would compel Apple to produce the required software
- 16th Feb 2016 – The court issues an order directing Apple to create the required software and gave Apple 5 days to apply for relief if it thought the order was “unreasonably burdensome”.
- Apple announced its intent to oppose the order. It stated that no government had asked for similar access
- On the same day the Apple CEO Tim Cook released an on-line statement explaining the rationale of Apple’s opposition and said that while they respect the FBI, the request they made threatens data security by establishing a precedent that the U.S. government could use to force any technology company to create software that could undermine the security of its products.
- On March 21, 2016, the FBI requested and was granted a delay, saying a third party had demonstrated a possible way to unlock the iPhone in question and some time was needed to test it
- On March 28, 2016, the FBI said it had unlocked the iPhone with the third party's help, and an anonymous official said that the hack's applications were limited; the Department of Justice withdrew the case.
- On April 7, 2016, FBI Director James Comey said that the tool used can only unlock an iPhone 5C like that used by the San Bernardino shooter, as well as older iPhone models lacking the Touch ID sensor. Comey also confirmed that the tool was purchased from a third party but would not reveal the source.
- There has been speculation about who the source was and the following have been put forward by various sources
 - Cellebrite (an Israeli company)
 - “professional hackers”
 - Azimuth Security (an Australian company)

NASSCOM Discussion Paper Sep 2020

- In Sep 2020 Nasscom put out a discussion paper titled “The Road Ahead for Encryption in India”
- The objective was to seek views on various issues regarding the deployment of encryption in India and the regulatory positions that could be adopted to address both the legitimate privacy and confidentiality needs of stakeholders and the legitimate needs of Law Enforcement Agencies

The Global Context as described in the Paper

- The revelations made by former employee of the United States' National Security Agency (NSA), Edward Snowden in 2013, marked a turning point in the decades long conversation surrounding encryption.
- The revelations which indicated mass surveillance conducted by the US government, led to worldwide public condemnation of the non-transparent and unbridled surveillance programs employed by the US government to spy on its citizens. The leaks were shocking as they revealed that instead of targeted surveillance of suspected criminals, which has long been accepted as an important component of law and order enforcement by the state, the US was indulging in an all-pervasive form of surveillance, collecting data on all its citizens purportedly to use it as intelligence should such a need arise in future.
- What was becoming increasingly evident, was that users, were now ever more cautious of the way they interacted with technology. Not only did the Snowden revelations lead to a call for greater government accountability and transparency, it led to a growing consumer demand for encrypted communication products.⁷ To protect internet users from this sort of government snooping, Internet companies stepped up their data security measures by incorporating strong encryption standards to prevent third party interception of data.
- Traditionally, the policy discussions have juxtaposed benefits of encryption from a data security and privacy position as detrimental to law enforcement capability. Given that at the start of 2019, 87 percent of Web traffic was encrypted, compared to just 53 percent in 2016.⁸, dealing with this conundrum has become important.

The Indian Context as described in the Paper

- In India, legal recognition of encryption technologies under domestic laws, did not come around till the late 1990s. The availability of sophisticated encryption technology in India was largely limited, *inter alia* owing to export controls and associated restrictions in the transfer of encryption technologies. However, rapid developments in digital communications coupled with limited decryption capabilities as acknowledged by Indian intelligence agencies in the backdrop of the 1998 Kargil conflict, led to an increased focus on development of domestic encryption technologies, as well as enabling greater encryption and decryption capacities for law enforcement and intelligence agencies.
- While the basis for the State's access to private communications on certain grounds existed in the Indian Telegraph Act, 1885¹⁰; encryption specific requirements were introduced by the Department of Telecommunications (**DoT**) in 1999, under the license agreements for TSPs and Internet Service Providers (**ISPs**) – wherein the license obligations barred default deployment of encryption beyond a key-size of 40 bits, in order to ensure lawful interception.
- However, it was only with the passage of the IT Act and subsequent amendments (under the IT Amendment Act) that encryption technologies were given legislative recognition. Most prominently, S.84A inserted in the IT Act by way of the 2008 amendments, empowered the Government to prescribe modes and methods for encryption, for ensuring the secure use and promotion of e-governance and e-commerce – paving the way for the Government to put in place a wider encryption policy.¹³ Further, S.69 empowered the Government to prescribe Rules on the procedures for interception and decryption of encrypted information on the limited grounds provided therein.¹⁴ Notably, the IT Amendment Act, focused not only on cyber-security and prevention of cyber-crimes, but also expanded the scope of the IT Act, to the prevention of a wider variety of online harms – including privacy harms.

The Blackberry Episode

- An important moment for India's stance on the use of encryption technology vis-à-vis concerns of national security, came against the backdrop of the 2008 Mumbai terror attacks, and involved Research in Motion (**RIM**)'s messaging service, BlackBerry Messenger (**BBM**). This business offering was RIM's most popular service, said to have been servicing 1 million Indian users in 2010.
- BBM offered 2 kinds of services in India - for enterprises, BBM installed the local BlackBerry Enterprise Server (**BES**) leading to all corporate consumer messages being routed through the BES with strong encryption. For individuals, RIM had an unencrypted BlackBerry Internet Service (**BIS**) network, which could be intercepted as plaintext, provided the local carrier removed any transport layer encryption it had added.
- When in the aftermath of the Mumbai terror attacks, it emerged that the perpetrators of the attacks had been communicating over BES services, the Indian government asked RIM to decrypt messages on demand, or alternately hand over their decryption key, failing which, the Government threatened to ban BBM in India. However, at the time RIM submitted that it did not have the keys to decrypt BES messages.
- It was only in 2013, that BlackBerry eventually arrived at a solution, that enabled the Indian Government to intercept data sent over BBM and BIS but clarified that such interception abilities will not extend to BES. Instead, BlackBerry offered to notify authorities of all companies utilizing BES.
- While the *Blackberry* incident eventually moved out of the news cycle, it marked the first major instance of the Government of India attempting to access encrypted digital communications from a communications intermediary.

Pegasus

- Developed by the NSO group of Israel
- The claim is it can only be sold to sovereign governments to be used against terrorists and organized crime
- Forbidden Stories and Amnesty International published a series of revelation alleging that 50,000 phone numbers had been targeted by this specific malware
- This led to a number of investigations in many countries
- This is very sophisticated malware that in its “0-click” variant does not require the user to actually do anything. The malware is capable of taking over control of the entire phone including its camera, microphone and all messages
- The Indian Supreme Court appointed a committee to look into the probable use of Pegasus in India.

Grounds in India for Interception of Communications – Indian Telegraph Act 1885

- i. Temporarily taking possession of telegraphs in case of a public emergency or in the interest of public safety, which possession is to last for the duration of the public emergency or public safety matter.
- ii. Intercepting or restricting transmission of messages or classes of messages transmitted over a telegraph directed towards (a) messages to or from any person or class of persons or (b) messages concerning a particular subject and which interception is in furtherance of interests of the sovereignty and integrity of India, the security of the State, friendly relations with foreign States or public order or for preventing incitement to the commission of an offence .

Grounds in India for Interception of Communications – IT Act 2000

Where the Central Government or a State Government or any of its officers specially authorised by the Central Government or the State Government, as the case may be, in this behalf may, if satisfied that it is necessary or expedient so to do, in the interest of the sovereignty or integrity of India, defence of India, security of the State, friendly relations with foreign States or public order or for preventing incitement to the commission of any cognizable offence relating to above or for investigation of any offence, it may subject to the provisions of sub-section (2), for reasons to be recorded in writing, by order, direct any agency of the appropriate Government to intercept, monitor or decrypt or cause to be intercepted or monitored or decrypted any information generated, transmitted, received or stored in any computer resource.

A recap of the Puttaswamy tests

- Legality
- Legitimacy
- Proportionality
- Procedural guarantees

Procedure for interception in India

- The Indian Telegraph Amendment (2007) rules lay down the procedure for interception. The salient features of these rules are
 - Requires authorization by the Home Secretary
 - Will ordinarily remain in force for 60 days
 - All such interception orders shall be reviewed by a review committee which will meet at least once in two months and will consist of
 - The Cabinet Secretary
 - The Secretary of the Law Ministry
 - The Secretary of the Telecommunications Ministry
- Records pertaining to such directions for interception shall be destroyed every six months

Purpose of Interception

- National Security
- Criminal Investigation
- Many countries have separate procedures for these two cases

Procedure in the USA

- There are separate courts (Foreign Intelligence Surveillance Courts) to evaluate and approve interception requests for collecting foreign intelligence with proceedings in these courts treated as confidential.
- Surveillance requests for investigation are to be posted to the jurisdictional district court (state trial courts) or federal court (for interception across district boundaries), with greater rights of access for the subject in case the recordings are intended to be used in prosecution.

Situations where separate procedures may apply

- i. In Canada, if the communications of a solicitor are to be intercepted, special judicial consideration is accorded to the matter.
- ii. In Japan, interception of communication with a physician, dentist, midwife, nurse, attorney, patent attorney, notary public or a person engaged in a religious occupation, when they are found to be related to those persons' services, is not permitted.
- iii. In the United States of America, the President may authorise interception for one year without court order if the communication is controlled exclusively by foreign powers.
- iv. In South Africa, pursuant to the order of the High Court, any surveillance of a journalist or practicing legal practitioner can be approved with specific limitations appropriate for their role as a journalist or practicing legal practitioner.

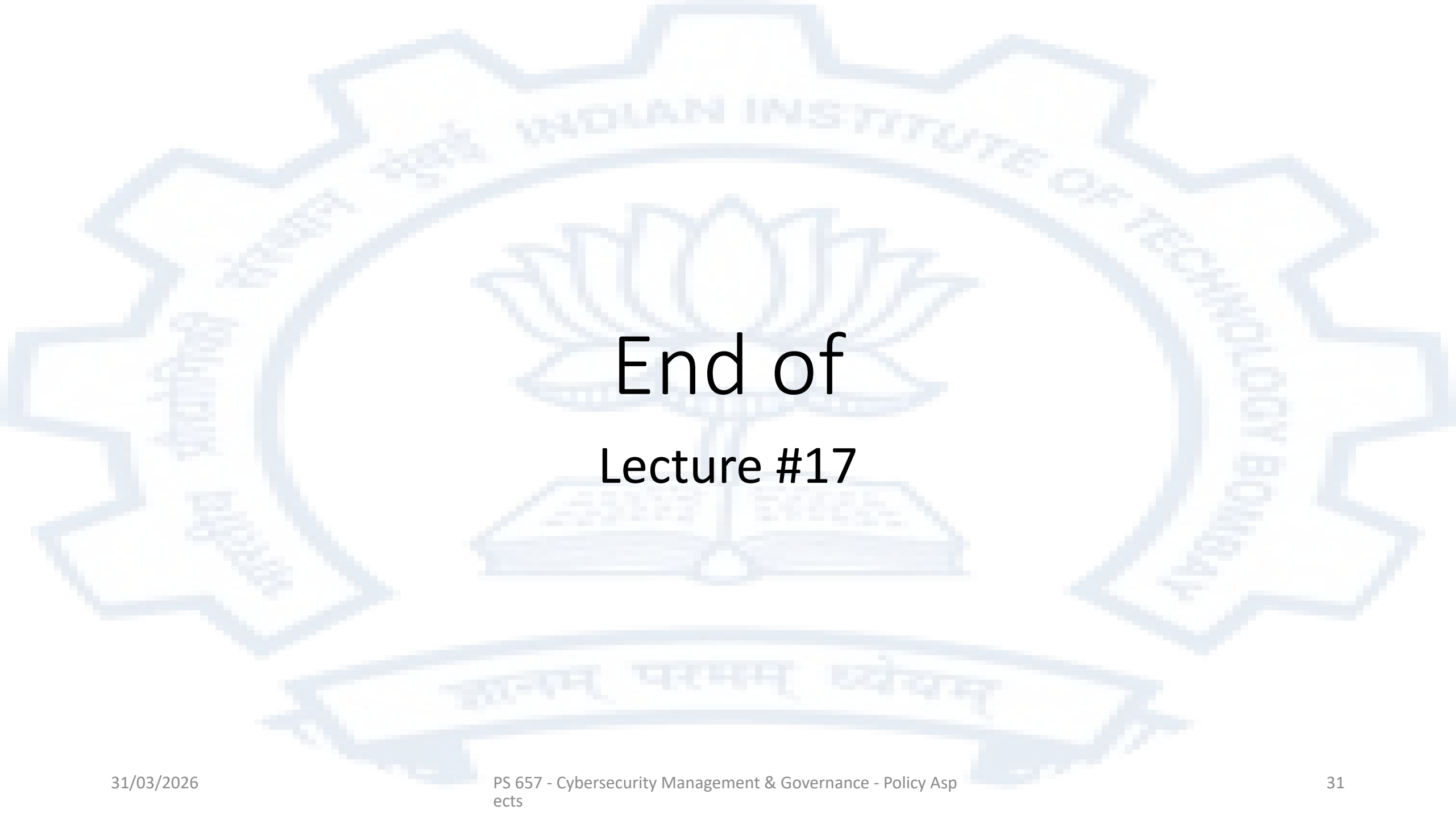
Principles for grievance redressal

The United Nations' Office of the High Commissioner on Human Rights' 2014 Privacy Report highlights that Article 2(3)(b) of the ICCPR 1966 places an obligation on State parties to provide effective remedy in case of violation of covenant rights. It recommended a variety of judicial, legislative and administrative remedies based on the following principles:

- i. Remedies must be known and accessible to anyone with an arguable claim that their rights have been violated.
- ii. State must tell its residents that a general surveillance regime or specific surveillance measures are in place with as much information provided about the measures as possible. Citizens must be able to challenge the measures.
- iii. Remedies must be prompt, thorough and provide for impartial investigation of alleged violations.
- iv. Remedies must be capable of ending ongoing violations, for example, through ordering deletion of data or other reparation. Such remedial bodies must have full and unhindered access to all relevant information, the necessary resources and expertise to conduct investigations, and the capacity to issue binding orders.
- v. Where violations rise to the level of gross violations, non-judicial remedies will not be adequate, as criminal prosecution will be required.

Summary

- There is often a conflict between privacy and security
- As security technologies improve and are used for privacy protection, the ability of law enforcement to intercept such communications is diminished
- Countries have had various procedural safeguards to ensure that any legal interception is adequately authorized and monitored, however there are significant differences in approaches by countries
- The lawful interception techniques worked well in traditional telecommunication systems but the extensive deployment of cryptography now presents a significant technical challenge

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and a banner at the bottom with the Sanskrit motto 'सत्यम् धर्मम् विद्यम्'. The text 'INDIAN INSTITUTE OF TECHNOLOGY BOMBAY' is written along the inner circle.

End of Lecture #17